

Sentinela Controladoria

Relatório Sobre Análise de Riscos de Segurança da Informação

Artur Guimarães dos Santos Leite, Marina Schwerz Bon, Pedro Boeira Webber

29 de setembro de 2025

1 Apresentação do Contexto da Empresa

A Sentinela Controladoria é uma empresa de controladoria e tecnologia financeira que busca ser referência na estruturação de dados voltados para a alta gestão empresarial. Sua missão é inovar a gestão das empresas por meio de um método avançado de controladoria, contando a história dos negócios com informações imersivas, assertivas, atualizadas e de forma simples. Os valores da organização incluem orientação para o resultado do cliente, responsabilidade com a informação, conexão entre pessoas, processos e tecnologia, aprendizado contínuo, simplicidade e ética.

1.1 Organograma

No organograma, os sócios compõem a Direção e definem a estratégia da empresa. A área de Controladoria é formada por controllers que realizam reuniões gerenciais com os clientes para analisar indicadores e orientar decisões. O setor de BPO executa os fechamentos mensais e rotinas operacionais. A área de Implantação é responsável pela recalibragem de softwares, implementação de novos processos e implantação de sistemas como o ERP 360 da Elevar nos contratos. A equipe de Tecnologia desenvolve soluções de Business Intelligence, presta suporte ao ERP 360 e apoia os controllers e a equipe de BPO. Esses departamentos formam a hierarquia central da organização e interagem com os sócios para garantir o alinhamento estratégico.



1.2 Produtos e Serviços

A empresa oferece serviços como BPO de controladoria, dashboards gerenciais de BI, implantação e suporte do ERP 360, consultorias e recalibragem de software. Os clientes são empresas do agronegócio, indústrias e distribuidoras, localizadas principalmente em RS, SC, PR e MT, com faturamento anual superior a R\$10 milhões.

1.3 Ambiente Tecnológico

O ambiente tecnológico é baseado no ERP 360 da Elevor e no Microsoft Power BI, além de ferramentas como Demander, Microsoft Office e Evernote. Embora existam sistemas críticos, não há um departamento específico de segurança da informação; a segurança é gerida pela área de tecnologia. A empresa acessa bases de dados de clientes para validações e fechamentos e armazena dados internos em planilhas dispersas, porém, está implantando um repositório central com capacidade para controle de acesso.

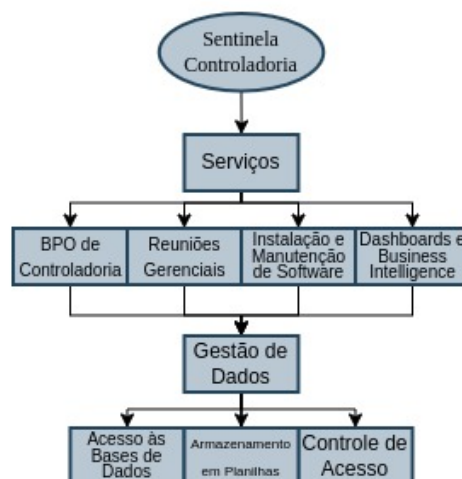
1.4 Partes Interessadas

A empresa possui clientes da área agropecuária, como indústrias e distribuidoras, localizadas principalmente no RS, SC, PR e MT, com faturamento anual superior a R\$10 milhões. Os principais funcionários são os controllers, assessores de BPO e o gestor de tecnologia. Os parceiros estratégicos incluem a Elevor, fornecedora do ERP 360 e a Microsoft, responsável pelo Power BI. Os controles atualmente observados na Sentinela são básicos e concentram-se na responsabilidade da área de Tecnologia, que é encarregada de gerenciar a segurança da informação, apesar de a empresa não possuir um setor específico dedicado a isso.

2 Definição e Descrição do Escopo

O escopo desta análise abrange as principais atividades e processos críticos da Sentinela Controladoria. A empresa presta serviços de BPO de controladoria, onde a equipe de BPO realiza os fechamentos mensais e rotinas operacionais. Na área de Controladoria, os controllers conduzem reuniões gerenciais com os clientes para analisar indicadores e orientá-los na tomada de decisões. O setor de implantação é responsável pela recalibragem de softwares, implementação de novos processos e implantação de sistemas como o ERP 360 nos contratos. Já a equipe de Tecnologia desenvolve dashboards de Business Intelligence e presta suporte ao ERP 360, além de dar apoio aos controllers e à equipe de BPO.

Essas atividades são consideradas críticas porque concentram o fluxo de dados financeiros e operacionais dos clientes e sustentam a prestação de serviços. O escopo inclui a avaliação dos processos de fechamento mensal e contabilidade, o desenvolvimento e entrega de dashboards de BI, a implementação e recalibragem de software e processos, o suporte ao ERP 360, e a gestão de dados dos clientes. Este último inclui o acesso às bases de dados dos clientes para validações e fechamentos, o armazenamento de informações em planilhas e computadores da empresa e o projeto de centralização de arquivos com controle de acesso. A avaliação buscará identificar os riscos associados a cada uma dessas etapas, considerando aspectos de segurança da informação, qualidade dos dados, conformidade legal e continuidade operacional.



3 Critérios de Avaliação de Risco

Uma avaliação de riscos exige a adoção de critérios claros que permitam mensurar a probabilidade de ocorrência dos eventos e os impactos decorrentes. Esses critérios servem como base para a classificação dos riscos identificados, possibilitando a priorização das ações de tratamento e a definição de estratégias adequadas de mitigação. Para tanto, são estabelecidos parâmetros de probabilidade e impacto que orientam a análise qualitativa e quantitativa dos riscos no contexto organizacional.

3.1 Probabilidade

A análise da probabilidade busca estabelecer a frequência ou chance de ocorrência de um evento de risco. Por meio de níveis graduais, é possível classificar desde situações de ocorrência excepcional até aquelas recorrentes, criando uma base objetiva para estimar a exposição da organização a diferentes ameaças.

Os níveis de probabilidade utilizados foram:

Número	Nível	Descrição
1	Muito Baixa	Ocorre em casos excepcionais
2	Baixa	Pode ocorrer mas pouco frequente
3	Moderada	Ocorre algumas vezes
4	Alta	Acontece com frequência relevante
5	Muito Alta	Acontece sempre ou em ciclos

3.2 Impacto

A avaliação do impacto visa medir as consequências que um evento pode gerar sobre os ativos da organização, considerando aspectos operacionais, financeiros, legais e reputacionais. A correta mensuração do impacto é essencial para compreender a gravidade do risco e orientar a priorização das medidas de mitigação.

Os níveis de impacto utilizados foram:

Número	Nível	Descrição
1	Muito Baixo	Sem efeito relevante
2	Baixo	Causa incômodo, mas é contornável
3	Moderado	Impacta entregas e gera retrabalho
4	Alto	Prejudica clientes e reputação
5	Crítico	Paralisa operações ou gera multa grave

3.3 Risco

A combinação entre a probabilidade de ocorrência e o impacto resultante permite determinar o nível de risco associado a cada cenário identificado. Esse processo possibilita a classificação e hierarquização dos riscos, fornecendo uma visão clara do grau de criticidade e dos pontos que exigem maior atenção estratégica.

Será considerada a seguinte matriz de risco:

PROBABILIDADE	Muito baixo	Baixo	Moderado	Alto	Crítico
Muito Baixa	1	2	3	4	5
Baixa	2	4	6	8	10
Moderada	3	6	9	12	15
Alta	4	8	12	16	20
Muito Alta	5	10	15	20	25

Onde:

Aceitável: Risco inferior a 5, não requer ações apenas o registro;

Aceitável com monitoramento: Nível de risco entre 6 e 10, não requer ações imediatas, mas é necessário acompanhamento;

Tratamento: Nível de risco entre 7 e 15, requer ações de tratamento;

Inaceitável: Nível de risco acima de 15, requer resposta imediata.

3.4 Tratamento de Riscos

A definição do tratamento de riscos consolida os resultados da avaliação, apresentando as medidas planejadas para mitigação, aceitação, transferência ou eliminação dos riscos identificados. Esse instrumento formaliza as responsabilidades, prazos e recursos necessários, garantindo que o processo de gestão de riscos seja conduzido de forma estruturada, rastreável e alinhada aos objetivos organizacionais.

Baseando-se na metodologia 5w2h, o Plano de Tratamento de Riscos Cibernéticos definido abrange a estratégia a ser seguida em situações decorrentes de riscos cibernéticos.

I. Identificar claramente o risco e o evento por ele causado, descrevendo tanto o incidente quanto suas consequências imediatas;

II. Investigar a fonte do problema com base na técnica dos cinco porquês, a fim de determinar as causas raízes e fundamentar a necessidade de mitigação;

III. Mapear o ambiente impactado, prevendo, quando necessário, o isolamento da área afetada para impedir a propagação do risco;

IV. Estudar a linha do tempo dos acontecimentos, reconstruindo o encadeamento dos fatos e apontando os momentos críticos da ocorrência;

V. Designar os responsáveis pela análise da ameaça e pela investigação do vetor de ataque, garantindo que profissionais especializados executem as etapas técnicas;

VI. Estudar detalhadamente a ameaça e o vetor utilizado, valendo-se de metodologias de segurança, ferramentas forenses e práticas de resposta a incidentes;

VII. Por fim, quantificar o prejuízo ocasionado e a estimativa dos recursos financeiros necessários para mitigar os impactos e restabelecer a normalidade.

Concluído o processo, o risco deve ser submetido à avaliação dos stakeholders. Caso ocorra o aceite do risco inicia-se o monitoramento contínuo até que ocorra um novo evento que exija reavaliação. Caso não haja aceitação, o tratamento é retomado, assegurando a constante adaptação da estratégia frente às mudanças do cenário de risco.

4 Apresentação dos Riscos

A apresentação de riscos tem como objetivo consolidar de forma estruturada os riscos identificados ao longo do processo de análise. Nessa etapa, são descritos os eventos potenciais, suas causas, ameaças associadas, vulnerabilidades exploráveis e possíveis consequências para a organização. A sistematização dessas informações permite não apenas a visualização clara do cenário de exposição, mas também a comparação entre diferentes riscos, favorecendo a priorização de ações e a tomada de decisão estratégica no âmbito da gestão de segurança da informação.

4.1 Eventos de risco

A identificação de eventos de risco busca reconhecer as situações que podem comprometer os ativos da organização, originadas de falhas internas, erros humanos, incidentes técnicos ou ataques externos. Essa etapa é essencial para delimitar claramente os cenários que devem ser monitorados e tratados e atribuir um valor associado ao risco, conforme ilustrado na tabela abaixo.

I. Ocorrência de Phishing: Clique em um link malicioso recebido via email;

II. Ocorrência de Malware: Perda de informações devido a um ransomware;

III. Vazamento acidental de dados: Acesso de uma pessoa não autorizada devido a credenciais expostas acidentalmente;

IV. Vazamento proposital de dados: Venda de informações confidenciais por um funcionário descontente com a empresa;

V. Perda acidental de dados armazenados: Comprometimento de sistemas, dados ou serviços críticos por exploração de vulnerabilidades em equipamentos desatualizados ou mal configurados;

VI. Complicações legais: Multas, penalidades, restrições operacionais ou danos reputacionais decorrentes da não conformidade com normas legais;

VII. Ataques a cadeia de suprimentos: Interrupção de sistemas, falha de serviços

críticos ou exposição de dados internos devido à exploração de vulnerabilidades ou falhas nos serviços de fornecedores, como a Microsoft e a Elevor;

VIII. Fraude financeira: Prejuízo devido a transações eletrônicas com uma entidade maliciosa.

Tabela 1 – Avaliação de riscos segundo a matriz de riscos.

Risco	Probabilidade	Justificativa	Impacto	Justificativa	Nota
Phishing	4 (Alta)	E-mails maliciosos são comuns e os colaboradores não têm treinamento.	3 (Moderado)	Pode causar retrabalho e indisponibilidade temporária.	12
Malware / ransomware	3 (Moderada)	Há exposição, mas não é diária; ausência de backups agrava.	5 (Crítico)	Pode paralisar operações e gerar multas.	15
Vazamento acidental de dados	3 (Moderada)	Senhas em planilhas e repositório em implantação aumentam a chance.	4 (Alto)	Afeta clientes e reputação.	12
Vazamento proposital (insider)	2 (Baixa)	Casos de funcionários mal-intencionados são menos prováveis.	5 (Crítico)	Divulgar dados pode gerar multas e paralisação.	10
Perda acidental de dados armazenados	4 (Alta)	Equipamentos desatualizados e falta de backup frequente.	4 (Alto)	Compromete dados críticos e serviços.	16
Complicações legais (LGPD etc.)	3 (Moderada)	Ausência de DPO e processos de conformidade.	5 (Crítico)	Multas e danos reputacionais.	15
Ataques à cadeia de suprimentos	2 (Baixa)	Depende de falhas em fornecedores; eventos são menos frequentes.	5 (Crítico)	Pode comprometer serviços essenciais.	10
Fraude financeira	2 (Baixa)	Controles de transações existem, mas podem falhar.	4 (Alto)	Prejuízo direto e impacto em clientes.	8

4.2 Identificar Ameaças

A análise de ameaças consiste em reconhecer os agentes ou fatores que têm potencial de explorar vulnerabilidades e causar incidentes de segurança. Ao mapear essas ameaças, torna-se possível compreender de forma mais precisa os riscos a que a organização está exposta.

I. Ocorrência de Phishing: Ocorrência de Phishing: Phishing e suas variedades;

II. Ocorrência de Malware: Ataques de ransomware;

III. Vazamento acidental de dados: Vazamento de credenciais por má configuração em um serviço;

IV. Vazamento proposital de dados: Funcionário descontente;

V. Perda acidental de dados armazenados: Exposição a ataques cibernéticos devido a equipamentos sem manutenção de segurança;

VI. Complicações legais: Ação regulatória ou sanção por descumprimento de normas, como LGPD ou outras legislações de proteção de dados;

VII. Ataques a cadeia de suprimentos: Ataques à cadeia de suprimento da Microsoft, capazes de comprometer serviços ou softwares essenciais fornecidos pela empresa;

VIII. Fraude financeira: Criminosos utilizando identidades falsas.

4.3 Identificar vulnerabilidades

A identificação de vulnerabilidades concentra-se nas fragilidades dos processos, sistemas e controles que podem ser exploradas pelas ameaças. Esse levantamento fornece a base para avaliar a probabilidade de ocorrência de incidentes e direcionar as medidas corretivas necessárias.

I. Phishing e suas variedades: Falta de conscientização ou treinamento dos usuários sobre segurança cibernética e validação de e-mails;

II. Ataques de ransomware: Ausência de backups regulares;

III. Vazamento de credenciais por má configuração em um serviço: Credenciais armazenadas de forma insegura;

IV. Funcionário descontente: Falta de controles de acesso e monitoramento de atividades de usuários privilegiado;

V. Exposição a ataques cibernéticos devido a equipamentos sem manutenção de segurança: Equipamentos desatualizados, sem patches ou com configurações inseguras;

VI. Ação regulatória ou sanção por descumprimento de normas, como LGPD ou outras legislações de proteção de dados: Falta de processos de conformidade, políticas de proteção de dados ou controles de auditoria e registro de dados;

VII. Ataques à cadeia de suprimento da Microsoft, capazes de comprometer serviços ou softwares essenciais fornecidos pela empresa: Dependência crítica de serviços externos sem alternativas ou redundâncias;

VIII. Criminosos utilizando identidades falsas: Controles de transações eletrônicas insuficientes.

4.4 Análise dos controles existentes

A análise dos controles existentes avalia as medidas já implementadas pela organização para proteger seus ativos de informação. O objetivo é determinar a eficácia e a abrangência desses mecanismos, identificando lacunas que possam reduzir a capacidade de prevenção, detecção ou resposta a incidentes.

I. Controles Organizacionais: A hierarquia da empresa está definida, com as funções de Direção, Controladoria, BPO, Implantação e Tecnologia. Essa estrutura proporciona alguma segregação de tarefas, por exemplo, os controllers cuidam das reuniões com clientes e a equipe de BPO realiza os fechamentos mensais. Entretanto, não há menção a políticas ou procedimentos formais de controle interno;

II. Controles de Segurança: A segurança da informação é gerenciada pela equipe de Tecnologia, mas sem diretrizes estruturadas. Existem dados distribuídos em diferentes computadores e planilhas, e o acesso a bases de dados dos clientes é feito para validações e

fechamentos. Um repositório central com controle de acesso foi adquirido e está em fase de implantação, o que indica uma evolução nos controles, embora ainda não operacional;

III. Controles Técnicos: O uso do ERP 360 e do Microsoft Power BI incorpora alguns mecanismos de controle de acesso e integridade de dados, mas o relatório não menciona a aplicação de criptografia, backups frequentes ou segregação de ambientes. A inexistência de um departamento de segurança torna a implementação de controles técnicos responsabilidade da equipe de Tecnologia;

IV. Controles de Conformidade: Não foram identificadas medidas específicas para assegurar conformidade com legislações como a LGPD ou com requisitos fiscais. A ausência de um encarregado de dados (DPO) ou de avaliações formais de impacto em privacidade sugere que a empresa está exposta a riscos legais;

V. Treinamento e Conscientização: Não há referências a programas de capacitação em segurança ou compliance para colaboradores. A formação de controllers e de analistas de BPO foca nas atividades operacionais, mas não aborda práticas de proteção de dados;

VI. Monitoramento e Auditoria: O contexto não traz evidências de monitoramento contínuo de riscos ou de auditorias internas para verificar a eficácia dos controles existentes. Os processos parecem ser monitorados de forma reativa, com foco em entregas operacionais;

Essa análise demonstra que os controles existentes são incipientes e centrados nas pessoas e nos processos, com carência de procedimentos formais, documentação e ferramentas específicas. Para que o processo de gestão de riscos seja efetivo, a Sentinela precisará fortalecer seus controles organizacionais, técnicos e de conformidade, além de promover cultura de segurança e privacidade.

4.5 Análise do impacto (CID)

A análise do impacto, considerando os princípios de Confidencialidade, Integridade e Disponibilidade (CID), mede os efeitos que a exploração de uma vulnerabilidade pode causar. Essa etapa permite compreender a gravidade dos riscos não apenas em termos técnicos, mas também sob a ótica operacional, legal e reputacional.

I. Confidencialidade: A ausência de políticas ou procedimentos formais de controle interno de segurança expõe a organização a acessos não autorizados. Dados distribuídos em diferentes computadores e planilhas, sem mecanismos de controle de acesso, aumentam o risco de divulgação acidental ou intencional de informações sensíveis. Além disso, a falta de criptografia na armazenagem e transmissão de dados compromete a confidencialidade, permitindo que informações críticas sejam visualizadas ou interceptadas por agentes não autorizados;

II. Integridade: A inexistência de políticas formais de controle de segurança, combinada com a ausência de mecanismos próprios de verificação de integridade de dados, torna as informações suscetíveis a alterações não detectadas. A falta de criptografia e de procedimentos robustos de backup aumenta o risco de modificação não autorizada ou corrupção de dados, comprometendo a integridade da informação;

III. Disponibilidade: A inexistência de backups frequentes e estratégias de recuperação coloca os dados e serviços críticos em risco, especialmente diante de incidentes como ransomware ou falhas de hardware. A ausência de monitoramento contínuo e mecanismos de mitigação para ataques de negação de serviço eleva a probabilidade de interrupções operacionais, impactando a continuidade dos processos essenciais da organização;

4.6 Descrever o Risco

A organização apresenta um risco cibernético decorrente de uma combinação de fatores que comprometem a confidencialidade, integridade e disponibilidade de seus ativos de informação. A ausência de políticas formais de controle de segurança, a falta de manutenção e atualização de equipamentos, a dependência de serviços de terceiros, bem como lacunas em processos de verificação de identidade e conformidade legal, criam múltiplas vulnerabilidades exploráveis, tornando-a suscetível a uma ampla gama de ameaças, incluindo phishing, ransomware, vazamento accidental ou proposital de dados, ataques à cadeia de suprimentos e fraudes financeiras. Consequentemente, a organização corre o risco de sofrer impactos significativos, tais como acesso não autorizado a informações sensíveis, comprometimento da integridade de dados críticos, interrupções operacionais, perdas financeiras, danos reputacionais e sanções legais por descumprimento de normas como a LGPD. Esse cenário evidencia que a segurança da informação da empresa não depende apenas da proteção contra eventos isolados, mas de uma abordagem integrada de mitigação, monitoramento e governança de riscos, capaz de lidar com múltiplas ameaças simultâneas e com a complexidade crescente do ambiente digital.

5 Plano de Tratamento de Riscos

Baseando-se na metodologia 5W2H, o plano de tratamento de riscos cibernéticos da organização define a estratégia a ser seguida diante da exposição a múltiplas ameaças, incluindo phishing, ransomware, vazamentos accidentais e proposital de dados, ataques à cadeia de suprimentos, fraudes financeiras e falhas de conformidade legal.

I. Identificar claramente cada risco, como o acesso não autorizado a informações sensíveis, comprometimento de sistemas críticos ou perdas financeiras, descrevendo o incidente e suas consequências imediatas sobre os princípios CID (Confidencialidade, Integridade e Disponibilidade);

II. Investigar a fonte de cada problema utilizando a técnica dos cinco porquês, buscando determinar as causas raízes, como falhas de configuração, falta de treinamento de usuários, equipamentos desatualizados ou ausência de políticas de conformidade, a fim de fundamentar a necessidade de mitigação;

III. Mapear os ambientes impactados, incluindo sistemas internos, serviços em nuvem e dispositivos críticos, prevendo, quando necessário, o isolamento de áreas afetadas para impedir a propagação de ataques ou vazamentos;

IV. Estudar a linha do tempo dos acontecimentos relacionados a cada incidente, reconstruindo o encadeamento dos fatos e identificando os momentos críticos de vulnerabilidade, como atualizações de software pendentes ou falhas de monitoramento;

V. Designar profissionais especializados para analisar cada ameaça e investigar os vetores de ataque, incluindo equipes de segurança da informação, administradores de sistemas e especialistas em compliance, garantindo a execução técnica adequada;

VI. Realizar estudo detalhado das ameaças e vetores utilizados, empregando metodologias de segurança, ferramentas forenses, análise de logs e práticas consolidadas de resposta a incidentes, de forma a identificar pontos de mitigação eficazes e restaurar a integridade e disponibilidade dos sistemas;

IV. Quantificar os prejuízos potenciais decorrentes de cada risco financeiro, opera-

cional, legal e reputacional, estimando os recursos necessários para implementar medidas de mitigação, reforçar controles de segurança, treinamentos e mecanismos de recuperação de dados.

Concluído o processo, cada risco será submetido à avaliação dos stakeholders. Caso haja aceite, inicia-se o monitoramento contínuo, garantindo vigilância constante até que novos eventos exijam reavaliação. Se o risco não for aceite, o tratamento retorna às etapas iniciais, assegurando a adaptação contínua da estratégia frente às mudanças do cenário de ameaças, vulnerabilidades e impactos.

As seções a seguir consideram a matriz de risco (probabilidade $\times$ impacto) descrita na Seção 3, classificando os eventos do mais urgente ao menos urgente. Para cada risco são apresentadas mitigações recomendadas que visam reduzir a probabilidade de ocorrência e/ou o impacto caso o evento se concretize.

5.1 Riscos Inaceitáveis

5.1.1 Perda acidental de dados armazenados.

A perda de dados críticos decorrente de falhas de hardware, ataques de ransomware ou configurações inseguras demanda ação imediata. Mitigações recomendadas:

- Implementar política de **backups automáticos e testados**, incluindo cópias fora do ambiente local (off-site ou nuvem).
- Estabelecer **planos de recuperação de desastres (DRP)** com simulações periódicas.
- Assegurar a **aplicação contínua de patches de segurança** e a substituição preventiva de equipamentos obsoletos.

5.2 Riscos de Tratamento – Alta Criticidade

5.2.1 Ocorrência de Malware (ransomware).

A ausência de mecanismos robustos de defesa torna a empresa vulnerável a malware capaz de comprometer a continuidade do negócio. Mitigações recomendadas:

- Adotar **antivírus corporativo e soluções EDR** (Endpoint Detection and Response) em todas as estações e servidores.
- Segmentar a rede, limitando a propagação de ataques.
- Restringir anexos executáveis em e-mails e utilizar **sandboxing** para detecção de códigos maliciosos.

5.2.2 Complicações legais – LGPD e outras normas.

O não atendimento às exigências legais pode gerar multas severas e dano reputacional. Mitigações recomendadas:

- Nomear um **Encarregado de Proteção de Dados (DPO)** e instituir **política de privacidade formal**.

- Realizar **avaliações de impacto à proteção de dados (DPIA)** regulares.
- Estabelecer e registrar procedimentos de **consentimento e tratamento de dados pessoais**.

5.3 Riscos de Tratamento – Média Criticidade

5.3.1 Ocorrência de Phishing.

A falta de conscientização da equipe aumenta a probabilidade de comprometimento por e-mails maliciosos. Mitigações recomendadas:

- Conduzir **programas de treinamento contínuo**, incluindo simulações periódicas de phishing.
- Configurar **SPF, DKIM e DMARC** para autenticação e validação de e-mails.
- Implementar **filtros antispam e análise de links em tempo real**.

5.3.2 Vazamento acidental de dados.

Credenciais expostas e repositórios em implantação elevam a chance de acesso indevido. Mitigações recomendadas:

- Concluir a **centralização de arquivos com controle de acesso**.
- Implementar **criptografia em repouso e em trânsito** para todos os dados sensíveis.
- Adotar **gestão de identidades e acessos (IAM)** com autenticação multifator.

5.4 Riscos Aceitáveis com Monitoramento

5.4.1 Vazamento proposital de dados.

A possibilidade de um insider agir maliciosamente é baixa, mas o impacto é elevado. Mitigações recomendadas:

- Aplicar **princípio do menor privilégio** e monitorar atividades de usuários privilegiados.
- Estabelecer **processo de desligamento seguro**, com revogação imediata de credenciais.

5.4.2 Ataques à cadeia de suprimentos.

A dependência de fornecedores críticos, como Microsoft e Elevor, pode expor a empresa a falhas externas. Mitigações recomendadas:

- Exigir **relatórios de conformidade e segurança** dos fornecedores.
- Manter **planos de contingência** e fornecedores alternativos para serviços essenciais.

5.4.3 Fraude financeira.

Embora menos provável, transações fraudulentas podem gerar prejuízos diretos. Mitigações recomendadas:

- Fortalecer a **autenticação de transações** (MFA, verificação por segundo canal).
- Implantar **alertas automáticos de movimentações suspeitas** e reconciliação diária.

5.5 Integração com a Metodologia 5W2H

Todas as ações acima devem ser detalhadas em planos 5W2H, especificando *o que* será feito, *quem* será responsável, *quando* e *como*, além de estimar os recursos necessários. A reavaliação periódica dos riscos garantirá que as medidas adotadas reduzam efetivamente a probabilidade ou o impacto, assegurando a continuidade do negócio e a proteção das informações críticas da Sentinela.

Referências

1. INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO/IEC 27005:2018 – Information technology – Security techniques – Information security risk management**. Geneva: ISO, 2018.
2. NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **NIST Special Publication 800-30: Guide for Conducting Risk Assessments**. Gaithersburg: NIST, 2012.